

5.

IMPLEMENTATION TIMELINE

What is, in general, the usual order of implementation for organizations?



FUNDAMENTALS

FUNDAMENTALS IMPLEMENTATION TIMELINE

The PCI DSS, in a worst case scenario of complying with all 12 requirements, have various types of demands:

- Data access controls (physical and logical);
- Documentation (policies, IR plans, role definitions);
- Actual controls (CCTV, removable media, visitor badges);
- Honestly, they touch on all areas of a security practice;

The PCI SSC defines a “Prioritized Approach” with six steps, that I usually distill into three moments:

1. Minimize data retention and system vulnerabilities;
2. Control and monitor applications and systems;
3. Add additional data/other controls necessary;

FUNDAMENTALS

IMPLEMENTATION TIMELINE

The first moment is about obvious flaws and obvious improvements. Here, we:

- Create immediate diagrams of networks and data flows
- Formally define the PCI DSS scope and analyze risks, as well as have an immediate IR policy for accidents;
- Ensure we don't store SAD, and minimize the CHD stored. We also ensure we encrypt data at rest and in motion;
- Change vendor defaults, remove unneeded systems / accounts / ports, and limit all traffic to our CDE;
- Ensure good account lifecycle (unique user IDs, lockouts on failed attempts, have good password practices, MFA, etc);
- Physically protect POI devices and physical areas with data;
- Perform vulnerability scanning and penetration testing;





FUNDAMENTALS

FUNDAMENTALS IMPLEMENTATION TIMELINE

The second moment is about protecting apps and systems:

- We ensure development protection against SW vulnerabilities, patching of vulnerabilities, and also timely patching of external software we purchase/license;
- We define access control policies to data based on roles, with a “least privilege” logic;
- We implement strong authentication + strong password practices for accounts;
- We implement strong logging measures, logging certain event types, and protections against log failures/removals;
- We scan for unauthorized wireless APs and have procedures to deal with these;
- We implement change detection on critical systems;

FUNDAMENTALS

IMPLEMENTATION TIMELINE

The third moment is about tying up the “loose ends”:

- Restricting displays/copies/transmissions of PAN data;
- Having good cryptography practices (key management, key-encryption key strength, split knowledge, etc);
- Having policies for change management of system configurations, activation/deactivation of systems, etc;
- Ensuring appropriate visitor controls, including badges, logs, escorting personnel, etc;
- Managing physical media with card data (inventorying, tracking movements, secure destruction, etc);
- Documenting all policies, procedures, roles, responsibilities for all areas so far;
- All “best practices” usually also come here (March 2025);



FUNDAMENTALS

IMPLEMENTATION TIMELINE

EXAMPLES

/01 ASSUMING ALL 12!

Notice this example roadmap is assuming all 12 requirements must be implemented. The general process remains in case of less - just with fewer items.

/02 GENERAL TO DETAILED

You can see a general pattern. We start with big, general controls and protections, and then slowly cascade down to detailed and refined controls.

/03 IMMEDIATE RETURNS

The first moment is about immediate protections against attacks, while the second and third moments are about supporting controls. Immediate returns.

FUNDAMENTALS

IMPLEMENTATION TIMELINE

KEY TAKEAWAYS

/01 THREE MAJOR MOMENTS

Based on the PCI SSC's "Prioritized Approach", we can condense the six key steps into three "moments". Each requirement usually fits into one.

/03 APPS + ACCOUNTS

The second moment is about strengthening apps and accounts. Robust development, timely patching, robust logging, strong authentication measures, etc.

/02 DATA + VULNERABILITIES

The first moment is about data issues + system issues. Inventorying everything, analyzing risks, minimizing data, protecting data, protecting systems, etc.

/04 TYING UP LOOSE ENDS

The third moment is about wrapping it up. Strong cryptography practices, visitor controls, change management, physical media management, etc.